

Security Testing Analysis Report

Name : Muhammad Shaheem

Reg no : 2023507

Overview

As requested, the four security tests were performed on the ESCMS (Secure Complaint Management System). Below are the details and results of each test.

Test T4: SQL Injection Attack

1. Test Overview

Test ID	T4
Test Name	SQL Injection - Login Bypass Attempt
Test Date	May 5, 2026
Tester	shehroz (Student)
Target System	ESCMS - Login Page (localhost:5173/login)
Category	Authentication / Input Validation
Severity	Critical
Status	PASS - Attack blocked

2. Objective

To verify that the ESCMS login page is protected against SQL injection attacks that attempt to bypass authentication by manipulating the SQL query logic.

3. Test Payload

Payload entered in the **USERNAME** field:

```
' OR 1=1 --
```

Password field: any arbitrary value

4. Expected vs Actual Result

Expected Result	Login should fail; system should reject the malformed input
Actual Result	Login failed - system returned: 'Invalid username or password.'
Test Outcome	PASS

5. Analysis

The ESCMS login page correctly rejected the SQL injection payload. The application did not expose any database errors or grant unauthorized access. This indicates that the system employs parameterized queries or prepared statements to sanitize user input before passing it to the database layer.

6. Evidence

Screenshot: Shows payload entered in username field and error response

Browser: Kali Linux - Firefox

URL tested: <http://localhost:5173/login>

7. Recommendation

Continue using parameterized queries throughout the application. Additionally, consider implementing a Web Application Firewall (WAF) and input length restrictions as additional defense layers.

✓ PASS — SQL injection attack blocked

Test T5: CSRF Token Validation

1. Test Overview

Test ID	T5
Test Name	CSRF Token Removal / Modification
Test Date	May 5, 2026
Tester	shehroz (Student)
Target System	ESCMS - Complaint Submission API (localhost:5173/api/complaints)
Category	Cross-Site Request Forgery (CSRF) Protection
Severity	High
Status	PASS - Request rejected

2. Objective

To verify that the ESCMS complaint submission endpoint enforces CSRF token validation and rejects requests that are submitted without a valid CSRF token.

3. Test Method

Using the browser DevTools Network tab:

- A legitimate complaint submission POST request was captured via the Network tab
- The request was replayed via DevTools with the x-csrf-token header removed or modified
- The server response was observed and recorded

4. Request Details

Method	POST
Endpoint	http://localhost:5173/api/complaints
CSRF Header	x-csrf-token (removed/modified in replay)
Content-Type	application/json
HTTP Version	HTTP/1.1

5. Expected vs Actual Result

Expected Result	Server should reject the request with a 403 Forbidden response
Actual Result	Server returned HTTP 403 Forbidden (1.18 kB response)
Test Outcome	PASS

6. Analysis

The server correctly identified the missing or invalid CSRF token and returned a 403 Forbidden response. This confirms that CSRF protection is active on the complaint submission endpoint. The system will not process state-changing requests without a valid synchronised token.

7. Evidence

Screenshot: DevTools Network tab showing 403 response on replay

Response status: 403 Forbidden, transferred: 1.18 kB (41 B size)

8. Recommendation

CSRF protection is working as intended. Ensure that all state-changing API endpoints (not just complaint submission) are covered by the same CSRF validation middleware.

✓ PASS — CSRF token validation enforced

Test T6: Cross-Site Scripting (XSS)

1. Test Overview

Test ID	T6
Test Name	Reflected / Stored XSS - Script Injection
Test Date	May 5, 2026
Tester	shehroz (Student)
Target System	ESCMS - Complaint Title & Description Fields
Category	Cross-Site Scripting (XSS)
Severity	High
Status	PASS - Script not executed

2. Objective

To verify that the ESCMS application sanitizes user input in complaint title and description fields, preventing script injection that would cause an XSS alert popup to appear.

3. Test Payload

Payload submitted in both **Complaint Title** and **Complaint Description** fields:

```
<script>alert('XSS')</script>
```

4. Test Method

- Logged in as user 'shehroz' (student account)
- Navigated to the complaint submission form
- Entered the XSS payload in the Title field and Description field
- Submitted the complaint and observed whether an alert() dialog appeared
- Also tested by entering payload directly in the browser URL bar

5. Expected vs Actual Result

Expected Result	Alert popup must NOT appear; script must be sanitized or escaped
Actual Result	No alert popup appeared; payload was treated as plain text
Test Outcome	PASS

6. Analysis

The ESCMS application correctly sanitized the XSS payload in both the complaint title and description fields. The script tags were either escaped or stripped before rendering, preventing the malicious JavaScript from executing in the browser. The URL-based reflected XSS attempt also showed no execution, confirming that route parameters are properly handled.

7. Evidence

Screenshot: Browser showing URL with script payload, no alert dialog visible

URL tested: http://localhost:5173/login<script>alert('XSS')</script>

8. Recommendation

XSS protection is functioning correctly. Ensure that output encoding is applied consistently across all dynamic content rendering areas, including admin dashboards and notification displays. Consider adding a Content Security Policy (CSP) header as an additional mitigation layer.

✓ PASS — XSS payload sanitized, no script execution

Test T9: Account Lockout / Brute Force Rate Limiting

1. Test Overview

Test ID	T9
Test Name	Account Lockout - Brute Force Rate Limiting
Test Date	May 5, 2026
Tester	shehroz (Student)
Target System	ESCMS - Login Page (localhost:5173/login)
Category	Authentication / Brute Force Protection
Severity	High
Status	PASS - Account locked after repeated failures

2. Objective

To verify that the ESCMS login page enforces an account lockout or rate limiting mechanism that prevents brute force attacks by blocking further login attempts after a defined number of consecutive failures.

3. Test Method

The following steps were performed:

- Navigated to the ESCMS login page at http://localhost:5173/login
- Entered an invalid username/password combination repeatedly
- The SQL injection payload ' OR 1=1 -- was used as the username with an arbitrary password
- Login was attempted more than 5 consecutive times with invalid credentials
- The system response after the threshold was exceeded was recorded

4. Lockout Details

Trigger Threshold	More than 5 consecutive failed login attempts
Lockout Duration	15 minutes
Error Message Shown	Too many login attempts. Please try again after 15 minutes.
URL Tested	http://localhost:5173/login
Browser	Firefox (Kali Linux)

5. Expected vs Actual Result

Expected Result	System should block further login attempts after 5 failures with a lockout message
Actual Result	System displayed: 'Too many login attempts. Please try again after 15 minutes.'
Test Outcome	PASS

6. Analysis

The ESCMS application correctly implements a rate limiting / account lockout mechanism on the login endpoint. After more than 5 consecutive failed login attempts, the system blocked further attempts and displayed a clear lockout message with a 15-minute cooldown period. This effectively mitigates brute force and credential stuffing attacks by limiting the number of attempts an attacker can make within a time window.

7. Evidence

Screenshot: Login page showing the lockout warning after repeated failed attempts
Message displayed: 'Too many login attempts. Please try again after 15 minutes.'
Login attempts made: more than 5 consecutive failures before lockout triggered

8. Recommendation

The account lockout mechanism is functioning as intended. For stronger protection, consider also implementing CAPTCHA after 3 failed attempts, IP-based rate limiting, and alerting administrators of repeated lockout events. Ensure the lockout applies per account and per IP to cover both targeted and distributed attacks.

✓ PASS — Account locked after 5 failed login attempts

Overall Summary

Test ID	Test Name	Result
T4	SQL Injection - Login Bypass	✓ PASS
T5	CSRF Token Removal / Modification	✓ PASS
T6	Cross-Site Scripting (XSS)	✓ PASS
T9	Account Lockout / Brute Force	✓ PASS

All four security tests have been successfully performed and passed.